UK GDPR and CDA

Data protection law in brief, and how it applies to an operator's retained communications data and disclosure capability

Prepared for Michael Rossi
October 2026 — legal brief, not legal advice

In one paragraph

UK GDPR (the retained EU regulation as amended) and the Data Protection Act 2018 govern every operation an operator performs on personal data, and retained communications data is personal data: it identifies, or can identify, living individuals. The operator is the controller of the retained store; the retention notice supplies the lawful basis (legal obligation) and the IPA restricts the purpose; the acquiring authority becomes a separate controller — under the law-enforcement regime in Part 3 of the DPA 2018 where it is a competent authority — on receipt. Data protection does not override the IPA and the IPA does not switch data protection off: the two apply together, and the design must satisfy both.

> **TALKING POINT**
> 'The IPA tells us what we must keep and to whom we may disclose it. UK GDPR tells us how to behave as the controller of it in the meantime. They are cumulative.'

1. The principles, applied

Article 5 principle	What it means for the retained store
Lawfulness, fairness, transparency	Lawful basis is Art 6(1)(c), compliance with a legal obligation (the notice). Transparency is limited by the IPA's confidentiality duties; the privacy notice should state that data may be retained and disclosed as required by law, without detail that would reveal operational capability
Purpose limitation	The sole purpose is retention for disclosure under lawful authority. No business use. Access to the store for fraud, analytics, marketing or customer service is a breach of this principle and of the IPA
Data minimisation	Retain exactly the fields the notice specifies and no more; return no more than the authorisation permits; do not enrich third-party identifiers by default
Accuracy	Time-segmented identity resolution; explicit gaps and nil-return vocabulary; quality controls against source; caveats travel with the data
Storage limitation	Twelve months maximum, keyed to event time; evidenced deletion; backups handled by crypto-shredding
Integrity and confidentiality (security)	Art 32 appropriate measures: encryption, compartmentation, per-request authorisation-bound access, audit, detection of misuse — with the TSA Code as the floor
Accountability	Record of processing (Art 30) entry for the retained store; DPIA (Art 35); recorded decisions; evidence pack; a named accountable owner

2. Roles

Party	Role	Why
Operator	Controller of the retained store	Generates the data in its own service, determines the means (architecture, vendor, security), relies on its own lawful basis
Home Office / Secretary of State	Not a controller of the retained store	Compels retention but never holds or directs the handling of the data
Acquiring authority	Separate controller of disclosed data, from receipt	Under DPA 2018 Part 3 (law-enforcement processing) for police and competent authorities; UK GDPR for others; Part 4 for the intelligence services
Platform and support vendors	Processors of the operator	Act on the operator's instructions; Art 28 contract required
A vendor that also determines means (e.g. a managed service deciding its own architecture)	Risk of joint controllership	Avoid by keeping policy decisions — schema, classification, scope rules — in the operator's hands

See the separate paper *Processor, Controller or Owner?* for the full argument. The short form: 'owner' is not a legal category, and the operator is a controller whose purpose was chosen for it.

3. Obligations that bite on the design

Obligation	Article	Design consequence
DPIA	Art 35	Mandatory: large-scale processing of data about individuals, with intrusive potential. One DPIA for the retention and disclosure capability, reviewed on every material change; it is also the right place to record the negative decisions
Record of processing	Art 30	A separate entry for the retained store with its own purpose, basis, categories, recipients, retention period and security description
Security of processing	Art 32	Measures appropriate to the risk — the CDA course's Module 10 is the implementation
Processor contracts	Art 28	Every vendor touching the store: documented instructions, confidentiality, security, sub-processor control, assistance, deletion/return at end, audit rights
Breach notification	Art 33–34	72 hours to the ICO for notifiable breaches; a wrongful disclosure is a breach. Pre-agree the route alongside IPCO and Ofcom reporting
Data protection by design and default	Art 25	Truncation at ingest, classification-driven scope enforcement, minimisation as architecture rather than policy
Subject rights	Art 15–22	Subject access, rectification, erasure, restriction, objection — each subject to exemptions (below). A defined route is needed; the request cannot simply be referred to the Home Office
International transfers	Art 44–49	Where any component, vendor or support function is outside the UK; a cloud region or offshore support desk is a transfer
DPO	Art 37–39	The DPO must be consulted on the DPIA and should be part of the design authority's governance

4. The exemptions — where the IPA and data protection meet

Data protection law anticipates compelled retention and disclosure and provides restrictions on subject rights and transparency, but they must be applied case by case, not as a blanket.

Provision	Effect	Caution
DPA 2018 Sch 2 para 2 — crime and taxation	Subject rights and transparency may be restricted to the extent they would prejudice the prevention or detection of crime	'To the extent' — a subject-access request about ordinary account data is not restricted just because the subject also appears in a disclosure
DPA 2018 s.26 and Sch 11 — national security	Exemption from most of the regime where required for safeguarding national security; ministerial certificate available	Narrow in scope; must be justified per case
DPA 2018 Sch 2 para 5 — disclosures required by law	Processing required by an enactment or court order is exempt from provisions that would prevent it	This is what lets the operator disclose under a Part 3 authorisation without breaching purpose limitation — it does not expand what may be disclosed
IPA confidentiality duties (e.g. s.95, s.255)	The operator must not reveal the existence or content of a notice or disclosure	A subject-access response must neither confirm nor deny that a disclosure occurred; the wording is a designed artefact

DESIGN CONSEQUENCE

Design consequence: the subject-rights process needs a route for retained data — who answers, which exemption applies, how the response is worded so that neither the existence nor the absence of a disclosure can be inferred — and the disclosure audit must be queryable by subject without that query itself constituting a disclosure. Record the exemption decision each time.

5. The law-enforcement regime on the other side

When a competent authority (police, NCA, HMRC and others listed in Sch 7 DPA 2018) receives disclosed data, it processes under Part 3 of the DPA 2018, not UK GDPR. Part 3 has its own principles, including a requirement to distinguish categories of data subject (suspect, victim, witness) and to distinguish fact from assessment. That is why the caveats and completeness statements the CDA course attaches to a disclosure matter: they help the receiving controller meet its own duty to distinguish what is known from what is inferred, and they bound the operator's accountability at the point of release.

6. Difficulties in practice

- **Two regimes, one dataset.** Teams tend to pick one — 'this is IPA data, GDPR doesn't apply' or the reverse. Both apply; the design must show both.
- **Purpose creep.** The retained store is a clean, well-indexed copy of exactly the data the business wants for fraud and analytics. The temptation is permanent; the control must be technical.
- **DPIA as paperwork.** A DPIA written after the architecture is fixed records risk rather than reducing it. Run it with the design authority, early.
- **Vendor contracts.** Specialist retention vendors are often on legacy terms predating UK GDPR; check for Art 28 compliance and for the production-access and portability terms the course calls for.
- **Subject-access wording.** Getting the neither-confirm-nor-deny response wrong, in either direction, is a regulatory failure.
- **Transfers hidden in support.** A follow-the-sun support desk or a cloud control plane outside the UK is a transfer, and a security question under the IPA and TSA too.
- **Breach routing.** Three regulators with three clocks; decide in advance.

7. Questions to ask

- Where is the DPIA for the retention and disclosure capability, who signed it, and when was it last reviewed?
- Is there a separate record-of-processing entry for the retained store with legal obligation as the basis and no business purpose?
- Show me the Art 28 terms for every vendor with access to the store.
- What happens, step by step, when a subject-access request arrives from someone who is the subject of a live authorisation?
- Is any part of the estate, or any support function, outside the UK?
- Can we prove no business query has ever run against the retained store?
- Who makes the breach-notification decision, and which bodies are in the playbook?

> **CAVEAT**
> Article numbers, Schedule references and the current status of the Data (Use and Access) Act 2025 amendments should be checked against the legislation in force before use as a design constraint.